



Scenario: "IkonPay Custody" (Hypothetical; CCSS v9 Level 2 target)

IkonPay Custody is a mid-size fintech company that offers merchant crypto settlement (B2B) for e-commerce platforms and marketplaces across India and Southeast Asia. The firm temporarily holds digital assets (minutes to days) and performs daily settlement to merchants, operating custody as an internal product unit with roughly 120 employees (all figures fictional). IkonPay is pursuing CCSS v9 **Level 2** readiness for the custody subsystem supporting BTC and EVM chains, and the assessment scope is limited to Aspect 1.01 (Key Material Generation) and Aspect 1.02 (Wallet Generation) requirements.

IkonPay uses a common custody pattern: a hot wallet (single-signer) for automated merchant payouts under a daily limit; a warm wallet (2-of-3 multisig) for treasury refills of the hot wallet and ad-hoc large settlements; and a cold wallet (2-of-3 multisig) for longer-term reserves. As an explicit exposure control, IkonPay caps hot-wallet holdings to 5% of total operational funds. For hot signing, IkonPay uses an HSM-backed signing service; for warm and cold signing, it uses hardware wallets for each signer. Warm wallets are handled by the security officer and two treasury operators and cold wallets are handled by the three co-founders.

IkonPay's definition of "wallet" differs by chain. For BTC, it uses descriptor-based wallets with separate xpub management for deposit address derivation, while spending keys are controlled by hot/warm/cold according to policy. For EVM, it uses a single address per wallet role (hot/warm/cold), with separation enforced through operational controls and the signing workflow.

For hot-wallet key material generation and signing, IkonPay runs a "Signer" service that requests key creation inside AWS CloudHSM and calls Sign() through an HSM client library; the private key is intended to never leave the HSM boundary. In production, the hot signing path is described as: Settlement API → Policy/Limit Engine → Tx Builder → Signer Service → Cloud HSM (PROD-CUSTODY) → Broadcast Gateway, with the key point that hot key material is intended to be generated and used within the HSM + signer system.

For warm- and cold-wallet key material generation, IkonPay conducts scheduled ceremonies where the intended design is that each signer generates their own key material on their own hardware wallet device. Prior to operational use, the Security Officer and the CISO conducted an assessment on these hardware wallets to validate the key generation mechanism's entropy restrictions. This review was formally documented and signed off. For warm signing workflow, the stated design is: Treasury Operator A (hardware wallet), Treasury Operator B (hardware wallet), and a Security Officer (hardware wallet) coordinate on a "Multisig Coordinator Laptop," which is intended by policy to be dedicated and offline and used only for transaction construction and partial signing; the partially signed transaction is then moved to an "online relay laptop" for broadcast. For cold signing workflow, IkonPay

states the process is similar to warm but intended to be executed during a scheduled bank-locker visit and ceremony, with the third signer's device stored at the bank locker between ceremonies. The transfer of the fully signed transaction from the coordinator laptop to the online relay system happens via a USB stick which is scanned for malware before use and wiped between uses as a part of the wallet policy. As an extension to IkonPay's ceremony controls, the process requires that before **every** warm and cold key-generation procedure, the device integrity routine is performed on each hardware wallet device, including a firmware/version check and a Ledger "Genuine Check," and the ceremony checklist is completed prior to key generation.

During interviews, the CISO states that for hot keys, the primary goal is that keys never touch disks and that the signer service is the only system intended to request signatures from the HSM; the CISO also states that hot single-signer usage is allowed because limits cap exposure and compensating controls exist, and that rationale has been documented. The platform engineer responsible for the signer service states that keys are generated by calling the HSM API. They also state that container images are not signed yet and checksum verification at deploy time is inconsistent and often manual. Treasury Operator A states that warm wallet setup involved Operator A generating their key on their hardware wallet and Operator B doing the same, but that the Security Officer key was generated on Operator A's laptop because the Security Officer's device was not arriving in time, and later the team "moved it"; they add that BTC deposit address generation uses the xpub for derivation and spending controls are separate. The Security Officer states they keep their signing device in a desk drawer for convenience and that they joined the multisig later by importing a configuration file they were sent. The compliance manager states that for geographic distribution, two signers are currently in the Pune office. The third signer's device was intended to be stored at a bank locker to satisfy geographic separation, but operationally the device is still kept locally in the Pune office. A transition to the bank-locker arrangement is planned but has not been implemented.